



AOS-CX 10.18 Hardening Guide

AOS-CX 10.18 Hardening Guide

Published: May 2026

© Copyright 2026 – Hewlett Packard Enterprise Development LP

Notices

The information provided here is subject to change without notice. Hewlett Packard Enterprise's products and services are covered only by the express warranty statements that come with them. This document does not constitute an additional warranty. Hewlett Packard Enterprise is not responsible for any technical or editorial errors or omissions in this document.

Confidential computer software. You must have a valid license from Hewlett Packard Enterprise to possess, use, or copy the software. In accordance with FAR 12.211 and 12.212, Commercial Computer Software, Computer Software Documentation, and Technical Data for Commercial Items are licensed to the U.S. Government under the vendor's standard commercial license.

Links to third-party websites will take you outside of the Hewlett Packard Enterprise website. Hewlett Packard Enterprise has no control over and is not responsible for the information outside the Hewlett Packard Enterprise website.

Open source code

This product includes code licensed under certain open source licenses which require source compliance. The corresponding source for these components is available upon request. This offer is valid to anyone in receipt of this information and shall expire three years following the date of the final distribution of this product version by Hewlett Packard Enterprise Company. To obtain such source code, please check if the code is available in the HPE Software Center at <https://myenterpriselicense.hpe.com/cwp-ui/software> but, if not, send a written request for specific software version and product for which you want the open source code. Along with the request, please send a check or money order in the amount of US \$10.00 to:

Hewlett Packard Enterprise Company

Attn: General Counsel

WW Corporate Headquarters

1701 E Mossy Oaks Rd, Spring, TX 77389

United States of America.



Legal disclaimer

The resource assets in this document may include abbreviated and/or legacy terminology for products. See [**www.arubanetworks.com**](http://www.arubanetworks.com) for current and complete product lines and names.

Table of contents

About this document.....	6
Latest version available online.....	6
About the examples.....	6
Identifying switch ports and interfaces.....	7
Identifying modular switch components.....	8
Overview.....	9
Syntax and Conventions.....	11
Software, Documentation, Security Advisories and Bug Bounty Program.....	11
Hardening the CX Management plane.....	11
Factory Defaults.....	12
Physical Security.....	15
Firmware Validation.....	16
Enhanced security mode.....	17
ServiceOS password authentication.....	18
Securing Switch Management Access Control.....	19
User Management and Password Control.....	19
Authentication, Authorization and Accounting (AAA).....	23
RadSec over RADIUS.....	31
Hardening SSH.....	32
Two Factor Authentication and Authorization.....	35
Summary.....	36
Session Management.....	37
Limiting Shell Access.....	37
Securing SNMP Access.....	38
Control Plane ACLs.....	39
Time Synchronization.....	40
Secure Copy.....	41
Hardening PKI.....	42
Hardening the Control Plane.....	46
Trusted Supply Chain.....	49
Support and Other Resources.....	50
Accessing HPE Aruba Networking Support.....	50
Accessing Updates.....	52
Warranty Information.....	52

Regulatory Information.....	52
Documentation Feedback.....	53

About this document

This document describes features of the AOS-CX network operating system. It is intended for administrators responsible for installing, configuring, and managing HPE Aruba Networking switches on a network.

Subtopics

[Latest version available online](#)

[About the examples](#)

[Identifying switch ports and interfaces](#)

[Identifying modular switch components](#)

Latest version available online

Updates to this document can occur after initial publication. For the latest versions of product documentation, see the links provided in [Support and Other Resources](#).

About the examples

Examples in this document are representative and might not match your particular switch or environment.

The slot and port numbers in this document are for illustration only and might be unavailable on your switch.

Understanding the CLI prompts

When illustrating the prompts in the command line interface (CLI), this document uses the generic term **switch**, instead of the host name of the switch. For example:

```
switch>
```

The CLI prompt indicates the current command context. For example:

```
switch>
```

Indicates the operator command context.

```
switch#
```

Indicates the manager command context.

switch(CONTEXT-NAME)#

Indicates the configuration context for a feature. For example:

```
switch(config-if) #
```

Identifies the **interface** context.

Variable information in CLI prompts

In certain configuration contexts, the prompt may include variable information. For example, when in the VLAN configuration context, a VLAN number appears in the prompt:

```
switch(config-vlan-100)#
```

When referring to this context, this document uses the syntax:

```
switch(config-vlan-<VLAN-ID>)#
```

Where <VLAN-ID> is a variable representing the VLAN number.

Identifying switch ports and interfaces

Physical ports on the switch and their corresponding logical software interfaces are identified using the format:

```
member/slot/port
```

On the 4100i Switch Series

- member: Always 1. VSF is not supported on this switch.
- slot: Always 1. This is not a modular switch, so there are no slots.
- port: Physical number of a port on the switch.

For example, the logical interface **1/1/4** in software is associated with physical port 4 on the switch.

On the 6000 and 6100 Switch Series

- member: Always 1. VSF is not supported on this switch.
- slot: Always 1. This is not a modular switch, so there are no slots.
- port: Physical number of a port on the switch.

For example, the logical interface **1/1/4** in software is associated with physical port 4 on the switch.

On the 6200 Switch Series

- member: Member number of the switch in a Virtual Switching Framework (VSF) stack. Range: 1 to 8. The primary switch is always member 1. If the switch is not a member of a VSF stack, then member is 1.
- slot: Always 1. This is not a modular switch, so there are no slots.

- port: Physical number of a port on the switch.

For example, the logical interface **1/1/4** in software is associated with physical port 4 in slot 1 on member 1.

On the 83xx, 93xx, and 100xx Switch Series

- member: Always 1. VSF is not supported on this switch.
- slot: Always 1. This is not a modular switch, so there are no slots.
- port: Physical number of a port on the switch.

For example, the logical interface **1/1/4** in software is associated with physical port 4 on the switch.



NOTE

If using breakout cables, the port designation changes to x:y, where x is the physical port and y is the lane when split to 4 x 10G or 4 x 25G. For example, the logical interface 1/1/4:2 in software is associated with lane 2 on physical port 4 in slot 1 on member 1.

On the 8400 Switch Series

- member: Always 1. VSF is not supported on this switch.
- slot: Specifies physical location of a module in the switch chassis.
 - Management modules are on the front of the switch in slots 1/5 and 1/6.
 - Line modules are on the front of the switch in slots 1/1 through 1/4, and 1/7 through 1/10.
- port: Physical number of a port on a line module

For example, the logical interface **1/1/4** in software is associated with physical port 4 in slot 1 on member 1.

Identifying modular switch components

- Power supplies are on the front of the switch behind the bezel above the management modules. Power supplies are labeled in software in the format: member/power supply:
 - member: 1.
 - power supply: 1 to 4.
- Fans are on the rear of the switch and are labeled in software as: member/tray/fan:
 - member: 1.

- tray: 1 to 4.
- fan: 1 to 4.
- Fabric modules are not labeled on the switch but are labeled in software in the format: member/module:
 - member: 1.
 - member: 1 or 2.
- The display module on the rear of the switch is not labeled with a member or slot number.

Overview

Security is a growing concern in today's all-digital enterprise infrastructure. Upper-level managers and IT administrators alike are held to higher accountability for the integrity and availability of their critical data and infrastructure. While clients and servers are often the focus of security discussions, the security of network devices such as switches, routers, and wireless access points should not be ignored. Critical enterprise data traverses these devices, and properly securing them is paramount to a stable and secure infrastructure.

The HPE Aruba Networking CX switching platform, powered by the AOS-CX network operating system, simplifies network operations by delivering automation, distributed analytics, security, and high availability to campus and data center networks. The microservices architecture around which AOS-CX is built delivers network-wide analytics and full programmability to enable complete network assurance.

The purpose of this document is to provide security guidelines and best practices for management features and protocols provided by the AOS-CX software, and to present sample configurations to illustrate these best practices in action. This document is not intended to be a comprehensive reference guide to the features and commands listed; for additional information on configuration syntax and advanced features referred to in this document, please obtain the latest software manual set from the **[HPE Aruba Networking Support Portal](#)**.

Some of the features in this document are not available on all switch platforms. Refer to **<https://feature-navigator.arubanetworks.com>** for a list of features supported on each platform.

Hardening Objectives

IETF BCP 61 points to a few definitions that help us define our goals, which we can summarize into three helpful points:

- Authentication: A security service that verifies an identity. This identity could be a user, a device, or a process.
- Data Confidentiality: A security service that protects data against unauthorized disclosure to unauthorized individuals or processes.

- **Data Integrity:** A security service that protects against unauthorized changes to data. Changes include intentional change and accidental change.

The applications and procedures we use in this document leverage these summarized definitions above and help to shape the following general guidelines:

- If there are methods, we can use to ensure the identities of the users and devices with which we interact, we should prefer these over insecure alternatives.
- We should limit the exposure to the equipment from sources we cannot trust, whenever possible. We should also make attempts to utilize encryption methods so that our data is not easily read by anyone besides the trusted receiver of the data.
- Assume that eventually, an event will occur that causes a need for reliable information we know we can trust. We need to make sure this data is safe, available for us to access, and unavailable to anyone else.
- This document helps you improve the overall network security by hardening the security of the management and control plane.

Operational Assumptions

- One or more authorized administrators are assigned who are competent to manage the device and the security of the information it contains, trained for the secure operation of the device, and who can be trusted not to deliberately abuse their privileges to undermine security.
- Authorized users are trusted to correctly install, configure, and operate the device according to the instructions provided by the device documentation.
- There will be no untrusted users and no untrusted software on component servers.
- The switch must be installed in a physically secure area where only authorized administrators have access to the physical device.
- Users will protect their authentication data.

Certifications

HPE Aruba Networking CX switches are designed to meet demanding security and compliance standards, offering a range of certifications that validate their reliability and suitability for diverse environments. These switches have achieved various government certifications, as detailed in the HPE **Aruba Networking standards, government validations, and accreditations Datasheet**, ensuring compliance with key regulatory requirements for secure networking. Additionally, Aruba CX switches align with the Center for Internet Security (CIS) Benchmarks, a globally recognized standard for secure configuration guidelines, which are outlined in the **CIS Benchmark for Aruba**. Together, these certifications and benchmarks demonstrate the commitment of HPE Aruba Networking to delivering secure, high-performance networking solutions that meet the needs of government, enterprise, and mission-critical environments.

Subtopics

Syntax and Conventions

This document provides examples for each configurable feature discussed. These examples follow a common format: commands and fixed options appear as fixed-width regular text, while configurable parameters appear in *italics*, as in the following:

```
switch(config)# ssh server vrf default
```

For more details on command syntax, refer to the documentation referenced for each feature, or use the built-in command syntax help on the switch by typing a partial command, then typing **?** (a question mark) to see possible options and parameters for that command.

Software, Documentation, Security Advisories and Bug Bounty Program

HPE Aruba Networking CX switch software, release notes, and user documentation can be found at the **[HPE Networking Support Portal](#)**.

Security advisories are published on the **[HPE Aruba Networking Security Advisory archive](#)**, and notification services are provided by a Security Alerts mailing list, with subscriptions offered via the **[self-service portal](#)**. For more information, refer to the **[Security Incident Response Policy](#)**.

HPE Aruba Networking also runs a Bug Bounty program for reporting security exploits and vulnerabilities. HPE Aruba Networking handles and discloses vulnerabilities in accordance with ISO/IEC 30111. Refer to **<https://bugcrowd.com/aruba-product-public>** for more information on the Bug Bounty program

Hardening the CX Management plane

The following section describes strategies to secure the switch management plane.

Subtopics

[Factory Defaults](#)

[Physical Security](#)

[Firmware Validation](#)

[Enhanced security mode](#)

ServiceOS password authentication

Securing Switch Management Access Control

Session Management

Limiting Shell Access

Securing SNMP Access

Control Plane ACLs

Time Synchronization

Secure Copy

Hardening PKI

Factory Defaults

Once the device boots, it is essential for an administrator to immediately connect to it and configure a password for the admin account. California signed into law bill SB-327 in 2018, requiring manufacturers of networking equipment to force users to create a password when they first connect to a device.

In a factory default state, AOS-CX devices are configured with the default user admin with no password. The user is prompted to create a password before access is given to the CLI, Web UI, and REST API:

```
Please configure the 'admin' user account password.  
Enter new password: *****  
Confirm new password: *****
```

The built-in management interface provides a way to access and manage the switch that is segregated from production traffic. Internal networks separated from production traffic are typically referred to as Out-Of-Band-Management networks (OOBM). By limiting the clients allowed to manage devices to only those who reside on the OOBM network, we sharply limit the large set of devices that can attempt to control the device.

In AOS-CX, the management interface is logically separated from the rest of the switch by means of a unique virtual routing and forwarding table (VRF), named the mgmt VRF. Please note that the mgmt VRF is unique in that it is permanently assigned to the physical management port and cannot be associated with any other switch interface; the management port itself cannot be associated with any other VRF.

The management interface is enabled by default to learn an IP address via DHCP. To configure the management interface with a static IP address, gateway, and DNS:

```
switch(config)# interface mgmt  
switch(config-if-mgmt)# ip static 10.1.1.5/24  
switch(config-if-mgmt)# default-gateway 10.1.1.1  
switch(config-if-mgmt)# nameserver 10.0.1.10 10.0.1.11
```

To show the status of the management interface:

```
switch# show interface mgmt  
Secondary Nameserver : 10.0.1.11  
Address Mode : static
```

```
Admin State : up
Mac Address : d0:67:26:11:11:11
IPv4 address/subnet-mask : 10.1.1.5/24
Default gateway IPv4 : 10.1.1.1
IPv6 address/prefix :
IPv6 link local address/prefix : fe80::d267:2611:1111:1111/64
Default gateway IPv6 :
Primary Nameserver : 10.0.1.10
```

The other VRFs available on an AOS-CX device upon first boot is the default VRF. The default VRF is automatically associated with all non-management interfaces, including Layer 3 routed ports, non-routed ports, and switched VLAN interfaces (SVIs) created on the switch, unless the interface is explicitly attached to another VRF.

The following management services are enabled by default on an AOS-CX switch:

- SSH on TCP port 22
- WebUI and read/write REST API on TCP port 443. (Any Connections to TCP port 80 will be automatically redirected to TCP port 443)

The 10000, 8xxx and 9300 Switch series ship with these services enabled only on the mgmt VRF, while 6400, 6300, 6200 and 5420 switches ship with these services enabled on both the default and mgmt VRFs.

For optimal security, manage switches from a dedicated management network when possible, and disable management services on all other VRFs.

To disable management services on all other VRFs :

```
switch(config)# no ssh server vrf <vrf-name>
switch(config)# no https-server vrf <vrf-name>
```

To view the configuration change :

```
switch # show ssh server vrf vrf1
SSH server is not enabled on VRF vrf1.
```

As the 6100, 6000 and 4100i Switch series does not have a dedicated management port or the associated VRF, management services are enabled only on the default VRF. Therefore, disabling management services is not a feasible solution for these platforms. For these switches, use other alternatives, such as [Control Plane ACLs](#) , an [SSH Allow list](#) and [Per-User management interface enablement](#) features to protect the management services.

Restoring the Switch to Factory Defaults

The recommended method to return an AOS-CX switch to factory default settings is to zeroize it. The following occurs when the zeroization process is initiated:

- The switch reboots to ServiceOS
- Primary and secondary software image files are backed up to memory from flash storage
- The entire flash storage device is overwritten with zeroes to securely erase all stored data

- The flash storage device is reformatted with a factory default filesystem
- Backed up software image files are written to flash in their original locations
- The switch reboots to the primary software image with a default configuration

There are four methods that may be used to zeroize a switch. First, an admin user may use the erase all zeroize command from the AOS-CX CLI:

```
switch# erase all zeroize
This will securely erase all customer data and reset the switch to factory
defaults. This will initiate a reboot and render the switch unavailable
until the zeroization is complete.This should take several minutes to one
hour to complete.
Continue (y/n)?
```

Second, an admin user may use the erase zeroize command from the ServiceOS CLI:

```
SVOS> erase zeroize
#####WARNING#####
#####
This will securely erase all customer data and reset the switch to factory
defaults. This will initiate a reboot and render the switch unavailable
until the zeroization is complete.This should take several minutes to one
hour to complete.
#####WARNI
G#####
Continue (y/n)?
```

Third, a user with physical access to the switch front panel and a FAT32-formatted USB storage device may zeroize the switch from the ServiceOS login prompt by entering the username zeroize and following the provided instructions:

```
ServiceOS login: zeroize
This will securely erase all customer data, including passwords, and reset
the
switch to factory defaults.
This action requires proof of physical access via a USB drive.
* Create a FAT32 formatted USB drive
* Create a file in the root directory of the USB drive named zeroize.txt
* Type the following serial number into the zeroize.txt file: xxxxxxxxxx
* Insert the USB drive into the target module
* Confirm the following prompt to continue
Continue (y/n)?
```

Finally, changing the switch security mode results in the switch being zeroized; see the [Enhanced security mode](#) section for more information.

Physical Security

The following sections describe physical security hardening workflows.

Front Panel Security

AOS-CX switches include a reset button on the front panel to allow users to perform the following reset operations:

Reset Type	Procedure	Outcome
Soft Reset	Press the reset button and release it before 5 seconds.	The switch operating system is cleared gracefully. The switch then reboots and runs self - tests.
Hard Reset	Press the reset button and release it between 5 to 20 seconds.	The switch reboots, like a power cycle. A hard reset is used, for example, when the switch CPU is in an unknown state or not responding.
Factory Reset	Press the reset button and release it between 20 to 25 seconds.	The switch will undergo the factory reset process.



NOTE

Factory Reset functionality is available from 10.13.1000 release in HPE ANW CX 6000 and 6100 series of switches.

This factory reset capability creates a security and denial-of-service risk if the switch is in a location where it is impossible to prevent physical access to the front panel. It is disabled by default and recommended that administrators disable this feature after its usage to prevent malicious use by an attacker with physical access to the device.

```
switch(config)# front-panel-security factory-reset
This command will enable front-panel factory reset capability, where user
can
trigger factory-reset via reset button. This feature will remain enabled
until
it is disabled, or a factory-reset is performed.
Continue (y/n)?
```

To view the configuration change -

```
switch# show front-panel-security status
Front panel factory reset           : disabled
First occurrence of front-panel factory reset : N/A
```

USB Auxiliary Port

The AOS-CX switch front-panel includes an USB Auxiliary port for the following purposes –

- USB Mass storage - flash drive for deploying, troubleshooting, backing up configurations, or upgrading switches
- Bluetooth Adapter - allows Bluetooth enabled devices to connect to and manage the switch on a wireless Bluetooth Personal Area Network (PAN)

The Bluetooth feature has been enabled by default in AOS-CX switches and designed for operational simplicity. The switch provides an IP address to paired devices though DHCP when they join the Bluetooth Personal Area Network. Paired devices can then manage the switch through following methods

- SSH
- Web UI
- REST API
- HPE Aruba Networking CX Mobile App

Refer to [Securing Switch Management Access Control](#) for details on securing these management connections.

This USB Auxiliary port is enabled by default so recommended to be disabled when not in use, and only temporarily enabled when needed.

To disable the USB Auxiliary port entirely (USB Mass Storage and Bluetooth Adapter), use the following command:

```
switch(config)# no usb
```

To view the configuration change :

```
switch # show usb
Enabled: No
Mounted: No
```

AOS-CX switches also have the support to disable only the bluetooth feature rather than disabling the USB Auxiliary port completely, to perform the same following configuration can be executed which is enabled by default :

```
switch(config)# bluetooth disable
switch # show bluetooth
Enabled           : No
Device Name       : 6300-SG9ZKN002Z
Adapter State     : Absent
```

Firmware Validation

All AOS-CX switch firmware is signed by HPE at the time the firmware is created. The firmware signature is verified at the time of download and verified at every boot. The public keys used to verify the firmware is stored within the bootloader and firmware. The firmware is digitally signed with RSA-3072 and SHA-256.

If the switch firmware validation fails at boot, the switch will fail to boot with one of the following error messages and drop the user into the ServiceOS login screen:

```
Error: Signature verification failed
Error: Signature not found
Error: Invalid signature
```

Alternatively, after loading the firmware to the boot bank – primary or secondary, administrators can verify the firmware integrity using below show command before booting the switch.

The verify option performs an integrity check that the image has a valid signature and is compatible with this system. The switch prevents the download of firmware without a valid signature.

```
switch# show images verify primary
The primary image is valid
switch# show images verify secondary
The image does not contain a signature
```

Enhanced security mode

AOS-CX provides two security modes that control access to certain system management features — standard and enhanced. All AOS-CX switches operate in standard mode by default, with no system-level restrictions in place for any functionality. The enhanced security mode disables access to the start-shell command in the AOS-CX CLI, as well as the ServiceOS commands config-clear, password, sh, and update.

In a dual management module switch, both the management modules should be set to same secure mode.

Changing the switch security mode is performed either through CLI or from the ServiceOS shell. All changes to the switch security mode (**standard** to **enhanced** or **enhanced** to **standard**) result in zeroization of the filesystem and a reset to factory defaults.

```
6300-VSF(config)# secure-mode enhanced
This will set the switch into enhanced secure mode. Before enhanced secure
mode is
enabled, the switch must securely erase all customer data and reset
to factory defaults. This will initiate a reboot and render the switch
unavailable until the
zeroization is complete.
Continue (y/n)? y
```

ServiceOS be used a secondary method to boot the switch in enhanced secure-mode. Reboot the switch to ServiceOS using the following command:

```
switch# boot system serviceos
One time boot to ServiceOS initiated.
Checking if the configuration needs to be saved...
```

This will reboot the system to ServiceOS and render the entire switch unavailable.

Access to ServiceOS is only available through the serial console.

Continue (y/n)?

Once the switch has rebooted and the ServiceOS login prompt is displayed, login as admin (no password is set by default). Use the following command to enable enhanced security mode:

```
SVOS> secure-mode enhanced
```

```
#####WARNING#####  
#
```

This will set the switch into enhanced secure mode. Before enhanced secure mode is enabled, the switch must securely erase all customer data and reset the switch to factory defaults. This will initiate a reboot and render the switch unavailable until the zeroization is complete.

```
#####WARNING#####
```

Continue (y/n)?

Entering **y** will cause the switch to reboot, zeroize the filesystem, then reboot an additional time.

To revert to the standard security mode, reboot to ServiceOS as above, login as admin, then use the following command:

```
SVOS> secure-mode standard
```

```
#####WARNING#####
```

This will set the switch into standard secure mode. Before standard secure mode is enabled, the switch must securely erase all customer data and reset the switch to factory defaults. This will initiate a reboot and render the switch unavailable until the zeroization is complete.

```
#####WARNING#####
```

Continue (y/n)?

ServiceOS shall default to standard secure mode if Zeroization fails while setting to standard or enhanced secure mode.

ServiceOS password authentication

By default, the ServiceOS shell (accessible only from the local switch console port) requires no password to login as admin; to enable password authentication for ServiceOS, use the following command from the configuration context:

```
switch(config)# system serviceos password-prompt
```

When this setting is enabled, logging in to the ServiceOS shell with the admin user requires the same password used to authenticate the admin user in the AOS-CX CLI or Web UI.

If this setting is enabled, a forgotten admin user password cannot be reset using ServiceOS; if there are no other local or RADIUS/TACACS user accounts with administrator-level access, the switch must be zeroized by entering the username zeroize at the ServiceOS login prompt to restore administrator access. See [password reset](#) for more information.

Securing Switch Management Access Control

Use the following console, SSH, Telnet, and HTTPS server strategies to secure the switch management access.

Subtopics

User Management and Password Control

Authentication, Authorization and Accounting (AAA)

RadSec over RADIUS

Hardening SSH

Two Factor Authentication and Authorization

Summary

User Management and Password Control

User Groups

A factory-default switch comes with a single user named admin member of built-in administrators group. Up to 63 local users can be added, for a total of 64 users including the default user admin. A user can belong to only one group. The switch provides the following built-in user groups with corresponding roles. Each of these roles comes with a set of privileges.

- Administrators—full access (privilege level 15)
 - Perform firmware upgrades
 - Make configuration changes
 - View all switch configuration information, including sensitive data such as ciphertext passwords
 - Add and remove local user accounts, and change user passwords
 - All REST interface methods (GET, PUT, POST, PATCH, DELETE) can be used
- Operators – limited access (privilege level 1)
 - Display-only CLI access
 - View non-sensitive configuration information
 - Only the REST interface GET method can be used
- Auditors – limited access (privilege level 19)

- Access to Commands in “auditor” context only
- Web-UI “system->Log Page” view only.
- REST Interface GET method available only for following resources only
 - Audit log: /logs/audit
 - Event log: /logs/event

Apart from the built-in groups, the switch enables you to create up to 29 user-defined local user groups, for the purpose of configuring local authorization. Local authorization uses role-based access control (RBAC) to provide role-based privilege levels plus optional user-defined local user groups with command execution rules. Each of the 29 user-defined groups support up to 1024 CLI command authorization rules that define what CLI commands can be executed by members of the group.

Sample Configuration to create user-defined local user group:

```
switch(config)# user-group sample-group
switch(config-usr-grp-sample-group)# 10 comment Deny all show aaa commands
switch(config-usr-grp-sample-group)# 10 deny cli command "show aaa .*"
switch(config-usr-grp-sample-group)# 20 comment Permit all other show
commands
switch(config-usr-grp-sample-group)# 20 permit cli command "show .*"
switch(config-usr-grp-sample-group)# exit
6200(config)# show user-group
```

GROUP NAME	GROUP TYPE	INCLUDED GROUP	NUMBER OF RULES
administrators	built-in	n/a	n/a
auditors	built-in	n/a	n/a
operators	built-in	n/a	n/a
sample-group	configuration	--	2

Security User Group

Security log commands for showing, clearing, and copying the security logs can be made available to a security user. To have a security user, the admin must create a security user group and add a user to the group. The admin must also grant permission to members of the security user group for the three security log commands. Only users who are members of the security group have permission to execute the security log commands. The admin user who created the security user group does not have permission to use the security log commands:

```
switch(config)# user-group security-group
switch(config-usr-grp-security-group)# permit cli command "show security-
logs*"
switch(config-usr-grp-security-group)# permit cli command "clear security-
logs"
switch(config-usr-grp-security-group)# permit cli command "copy security-
log*"
```

```
switch(config-usr-grp-security-group)# exit
switch(config)# user security-user group security-group password
Adding user security-user
Enter password:*****
Confirm password:*****
```

Showing the security logs:

```
switch# show security-logs
```

Copying the security logs:

```
switch# copy security-log sftp://user1@99.99.99.99/coredump.xz vrf mgmt
```

Hardening Password Rules

When managing an AOS-CX Switches, setting up a secure network is essential. A crucial factor in security is the selection of a strong password. Passwords are never displayed in plaintext format in CLIs and config files. Passwords are encrypted when stored in the config file .

Passwords must:

- Contain only ASCII characters from decimal 33 to 126 (Hexadecimal 21 to 7E). Spaces are not allowed
- Contain at most 64 characters.

Passwords are portable to different switch using default or customer configured non-default export key. The password complexity feature will help organization to set password policy for their administrators

Password Complexity

The password complexity feature helps in enforcement of complexity rules when configuring local user account passwords. It is disabled by default. The password complexity feature will help organization to set password policy for their users. Remember to enable the password complexity feature after configuring it for the rules to be enforced. Enabling or changing password complexity settings affects password creation or password change after the password complexity feature is enabled or changed.

The following enforcement will apply to new user creation or a password update once the password complexity feature is enabled:

- User creation/Password update with `ciphertext-password` is not allowed, because password complexity check cannot be performed on ciphertext password.
- The following password complexity check will be enforced

```
switch(config)# password complexity
switch(config-pwd-cplx)# minimum-length 9
switch(config-pwd-cplx)# history-count 4
switch(config-pwd-cplx)# position-changes 5
switch(config-pwd-cplx)# enable
switch(config-pwd-cplx)# exit
switch # show password-complexity
```

Global password complexity checking criteria:

Password complexity	: Enabled
Previous passwords to check	: 4
Minimum password length	: 9
Minimum position changes	: 5
Maximum adjacent characters count	: 0
Password composition	
Minimum lowercase characters	: 1
Minimum uppercase characters	: 1
Minimum special characters	: 1
Minimum numeric characters	: 1

Non-Default Export Password

The export password is used to transform critical sensitive information into ciphertext suitable for exporting and showing by commands such as `show running-config`. Transformation enables safe switch configuration import and export. All factory-default switches have identical default export passwords. For security, it is recommended that you set the same non-default export password on every switch in a group that will exchange sensitive configuration information. Only switches with identical export passwords can exchange sensitive configuration information.

```
switch# show service export-password
Export password: default
switch# config t
switch(config)# service export-password
Enter password: *****
Confirm password: *****
switch(config)# show service export-password
Export password: custom
```

Built-in Admin Account Password Reset

When administrators forget their switch console passwords, they must endure a time-consuming reset process, resulting in loss of productivity. If there are multiple administrators for the switch, it is recommended to reset the password using another administrator account. There are two ways to reset the password in case there is single admin user only for the switch:

Reverting the switch to factory defaults

1. At the manager command prompt, enter `erase startup-config`.

```
switch(config)# erase startup-config
```

2. Boot the switch without saving the current configuration

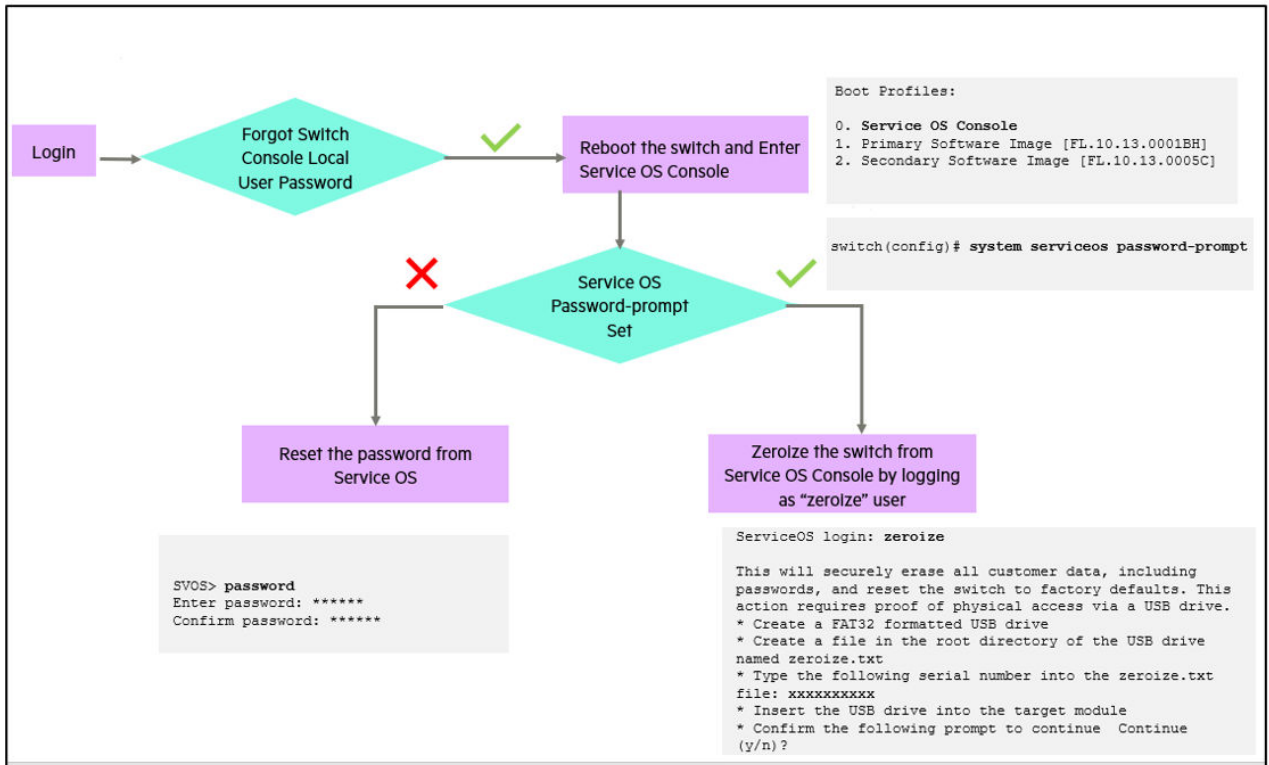
```
switch# boot system
Do you want to save the current configuration (y/n)? n
This will reboot the entire switch and render it unavailable until the
process is complete.
```

```
Continue (y/n)? y
```

The system is going down for reboot.

Resetting the switch admin password using the serviceOS console

Perform this task only when the switch admin user password has been forgotten:



Refer to the “Managing users and groups” section of the **Security Guide** for your switch model for more information.

Authentication, Authorization and Accounting (AAA)

AOS-CX have following management interfaces for accessing the switch for configuration and management -

- Console
- SSH
- Telnet

- https-server – Web UI and REST API



NOTE

Telnet is not a recommended method to access the switch for configuration and management, as it is not a secure communication. It is not enabled by default on any VRF.

User accounts for accessing these management interfaces can be stored locally or managed on remote TACACS+ or RADIUS servers. AAA (Authentication, Authorization, and Accounting) is the security framework to manage user access, enforce privileges, and log the user access records.

The following table describes supported AAA services based on the user account management methods:

User Account Management	Local	TACACS+	RADIUS
Authentication	Yes	Yes	Yes
Authorization	Yes, RBAC	Yes, Per Command Authorization and RBAC	No
Accounting	Yes	Yes	Yes

Authentication

Authentication is the process of identifying a user and granting them access to the network. Most of the time, this is done through traditional username and password credential, but it could be extended to SSH public key authentication. The following table describes supported authentication types based on their user account management methods.

User Account Management	Local	TACACS+	RADIUS
Authentication Type	• Username/Password • SSH Public Key • SSH two - factor Authentication	Username/Password	• Username/Password • SSH two - factor Authentication

Local Authentication

Local user names and passwords are configured on a per-switch basis and provide the most basic form of authentication. Local authentication is often used as the fallback login method. Local authentication can provide a minimum-security level should the primary method fail, but does not completely disable management access to the switch. To configure a local administrator-level user named localadmin with interactive password entry:


```
switch(config)# user localadmin group administrators password
Enter password: *****
Confirm password: *****
```

To create an operator-level user named **localoperator** with a plaintext password:

```
switch(config)# user localoperator group operators password plaintext
abcdefghijklmnop
```

An administrator can also enter a password as a ciphertext string rather than being entered in plaintext. In AOS-CX, ciphertext passwords cannot be generated manually; they must be copied from another switch with the same export password configured. By default all the switches will have same export password. Refer to [Non-Default Export Password](#) for the configuration. Once the export passwords on the source and destination switches are the same, copy the ciphertext password from the source switch and apply it to the destination:

```
switch(config)# user localadmin group administrators password ciphertext
myCipherText
```



NOTE

If password complexity is enabled, ciphertext password configurations are not allowed.

Local Authentication Configuration Task List

Task	Configuration	Show Commands
Enable local authentication for desired management interface Default – Includes all the management interfaces	aaa authentication login <console/default/ssh/telnet/https> - server > local	show aaa authentication
Limit the login attempts	Console: aaa authentication console - login - attempts <1 - 10> console - lockout - time <1 - 3600s> SSH/Telnet/https - Server: aaa authentication login - attempts <1 - 10> lockout - time <1 - 3600s>	show aaa authentication show authentication locked - output - users

Remote Authentication

Remote Authentication involves the use of remote RADIUS, RadSec and TACACS+ servers for authenticating the management users. Remote AAA servers are used as single point of management to

configure and store user accounts. They are often coupled with directories and management repositories, simplifying the setup and maintenance of the end-user accounts.

Remote Authentication Configuration Task List

Task	Configuration	Show Commands
Configure the server	RADIUS Server: radius - server host <IPv4/IPv6/FQDN> key plaintext <secret - key> > vrf <vrf - name> RadSec Server: radius - server host <IPv4/IPv6/FQDN> key plaintext <secret - key> > tls vrf <vrf - name> TACACS+ Server: tacacs - server host <IPv4/IPv6/FQDN> key plaintext <secret - key> > vrf <vrf - name>	show radius - server detail show tacacs - server detail
Server Group Creation and Association. The order in which servers are added to a group is important. The server added first is accessed first, and if necessary, the second server is accessed second, and so on.	RADIUS Server : aaa group server radius <group - name> server <IPv4/IPv6/FQDN> vrf <vrf - name> RadSec Server: aaa group server radius <group - name> server <IPv4/IPv6/FQDN> tls vrf <vrf - name> TACACS+ Server : aaa group server tacacs <group - name> server <IPv4/IPv6/FQDN> vrf <vrf - name>	show aaa server - groups
Enable local authentication for desired management interface Default – Includes all the management interfaces	aaa authentication login <console/default/ssh/telnet/https - server> <group - name>	show aaa authentication
Auth - Type “chap”	radius - server auth - type chap	show radius - server

Task	Configuration	Show Commands
By default CX switch uses “pap” as auth - type. “Chap” is stronger authentication method than pap	tacacs - server auth - type chap	show tacacs - server
Source Interface To ensure that all traffic sent from the switch to the AAA server uses the same source IP address	ip source - interface <radius/tacs> <ip - address> ipv6 source - interface <radius/tacs> <ipv6 - address>	Show ip source - interface Show ipv6 source - interface
Role Assignment in RADIUS	• Aruba - Admin - Role VSA - Map the user to the matching local user - group name. • Aruba - Priv - Admin - User VSA - Extract the privilege level (1, 15, or 19) and map the user to the local user - group corresponding to this privilege level (1=operators,15=administrators, 19=auditors). Privilege levels 2 to 14 may also be used with matching local user groups named 2 to 14. • RADIUS Service - Type - Map Administrative - User(6) to administrators and map NAS Prompt - User(7) to operators	
Role Assignment in TACACS+	• Aruba - Admin - Role VSA - Map the user to the matching corresponding local usergroup Name • TACACS+ priv - lvl attribute - Extract the privilege level (1, 15, or 19) and map the user to the local user - group corresponding to this privilege level (1=operators,15=administrators, 19=auditors).	

Task	Configuration	Show Commands
	Privilege levels 2 to 14 may al so be used with matching local user groups named 2 to 14.	

Authentication Fallback and Fail through

To prevent authentication failure because of Remote AAA Server failure, it is recommended to configure more than one remote AAA Server

When defining the server access sequence for authentication with a aaa authentication login default, there is an implied local included as the last item in the list. If no remote AAA servers can be reached, local authentication will be attempted.

Normally, authentication success or failure is performed by the first reachable AAA server. A rarely needed feature named "Authentication fail-through" is available. If authentication fail-through is enabled and authentication fails on the first reachable AAA server, authentication is attempted on the second AAA server, and so on, until successful authentication or the server list is exhausted. Enabling Authentication fail-through is typically unnecessary because the user credential databases should be consistent across all AAA servers. Authentication fail-through might be helpful if your AAA user credential databases are not quickly synchronized across all AAA servers

To configure and view the authentication fail-through feature:

```
switch(config)# aaa authentication allow-fail-through
switch# show aaa authentication
AAA Authentication:
Fail-through                : Enabled
Limit Login Attempts        : Not set
Lockout Time                : 300
Console Login Attempts      : Not set
Console Lockout Time        : 300
Authentication for default channel:
-----
GROUP NAME                  | GROUP PRIORITY
-----
local                       | 0
```

Per-User Management Interface Enablement

By default, switch users are enabled for accessing the switch through all these available management interfaces: ssh, telnet, https-server, console. Additionally fine-grained command authorization can be performed using RBAC , but it is applicable only for the CLIs not for Web-UI/REST API requests . Hence HPE ANW recommends enabling the specific management interfaces for the users based on the user type using below ways -

Local Per-user Management Interface Enablement

Local per-user management interface enablement is performed with CLI command. Example of disabling the SSH management interface for local user admin1.

```
switch(config)# no user admin1 management-interface ssh
switch(config)# show user-list management-interface
USER ENABLED MANAGEMENT INTERFACE(S)
-----
admin  ssh,telnet,https-sever,console
admin1 telnet,https-server,console
```

Remote TACACS+ and RADIUS

For remote TACACS+ and RADIUS servers, per-user management interface enablement is performed by configuring the AOS-CX VSA Aruba-User-Mgmt-Interface. On the TACACS+ or RADIUS server, the AOS-CX VSA Aruba-User-Mgmt-Interface must be set to a comma-separated list of management interface names for which login is permitted by the associated user. Management interfaces omitted from the list are disabled for the associated user. A maximum of four management interface names are allowed, with each management interface name given once. Permitted management interface names (always lowercase) are as follows:

- –ssh
- –telnet
- –https-server
- –console

The VSA has a maximum length of 32 characters. The VSA is ignored by the switch if longer than 32 characters. When a user login fails because of an attempt to use a management interface that is not allowed, an event log is available indicating the enabled management interfaces as received in the TACACS+ or RADIUS VSA.

When using a RADIUS server other than ClearPass Policy Manager (CPPM), before setting the Aruba-User-Mgmt-Interface VSA, you must first define the VSA on the RADIUS server in file

```
ATTRIBUTE Aruba-User-Mgmt-Interface 69 string
```

Example RADIUS server VSA value that enables the two named management interfaces (ssh, telnet) while disabling the two unnamed management interfaces (https-server, console):

```
Aruba-User-Mgmt-Interface = "ssh,telnet"
```

Example RADIUS server VSA value that enables all four management interfaces:

```
Aruba-User-Mgmt-Interface = "ssh,telnet,https-server,console"
```

Authorization

Authorization controls how authenticated users execute commands and interact with the switch. Authorization uses role-based access control (RBAC) to provide role-based privilege levels plus optional user-defined local user groups with command execution rules.

```
Switch(config)# aaa authorization commands <console | default | ssh |  
telnet > group <tacacs | local | none > <tacacs | local | none>
```

- TACACS+ Authorization - Upon successful user authentication, the user is assigned their role by the TACACS+ server. See also User role assignment using TACACS+ attributes .TACACS+ authorization provides command filtering to allow/disallow individual command or command set execution. Each command is sent to the TACACS+ server for approval, and the switch then allows/disallows command execution according to the server response.TACACS+ authorization applies only to the CLI interface.
- RADIUS Authorization - Command authorization is not supported by RADIUS servers, however, user-defined local user groups can be configured with command-authorization rules, providing locally configured per command authorization for members of such groups.
- Fallback - Local authorization can be used as a fallback for the situation in which communication is lost with all TACACS+ servers after a successful authentication.
- When defining the server access sequence for authorization with above aaa authorization commands, it is recommended to always include either local or none as the last item in the list
- Failthrough – Authorization fail-through is recommended only for deployments where there are potential synchronization issues, so authorization will be failing in one server but succeeding in other.

```
Switch(config)# aaa authorization allow-fail-through  
switch# show aaa authorization  
***** Command authorization *****  
Fail-through : Enabled  
Authorization for default channel:  
-----  
GROUP NAME | GROUP PRIORITY  
-----  
local | 0
```

Accounting

Local Accounting records all the CLI and REST access activities by users from all channels. It logs and helps to track all the configuration changes and show command executions happened at the switch for auditing or accounting purposes. This accounting information is captured and made available locally (Enabled by default and always active) and, if desired, for sending to remote AAA servers:

- Exec Accounting: user login/logout events.
- Command accounting: commands executed by users.
- System accounting: remote accounting On/Off events.
- Interactions on the non-CLI interfaces: REST and WebUI.

The following is not captured or made available as accounting information:

- CLI commands that reboot the switch.
- Interactions in the bash shell. (On the other hand, logging of “start-shell” CLI is supported . It helps in auditing)

Sample accounting information:

```
Switch# show aaa accounting log all
-----
Command logs from previous boots
-----
2023-06-09T05:50:27.765+00:00 acctsyslogd[2788]: AUDIT|CLI "enable" executed
by user 'admin' from address '0.0.0.0' through CONSOLE session which
resulted
in success at timezone UTC.
```

Remote Accounting

For remote accounting, the information is sent to the first reachable remote server that was configured with this command for remote accounting. If no remote server is reachable, local accounting remains available by default

To enable and view the accounting configuration:

```
Switch(config)# aaa accounting all-mgmt <console|default|https-server|ssh|
telnet> start-stop <group|local>
switch# show aaa accounting
AAA Accounting:
  Accounting Type                : all
  Accounting Mode                 : start-stop
  Accounting Fail-through        : Disabled
Accounting for default channel:
-----
-----
GROUP NAME                      | GROUP PRIORITY
-----
-----
local                          | 0
```

RadSec over RADIUS

The RADIUS protocol uses UDP as underlying transport layer protocol. RadSec is a protocol that supports RADIUS over TCP and TLS. In conventional RADIUS requests, security is a concern as the confidential data is sent using weak encryption algorithms. The access requests are in plain text includes information such as user name, IP address and so on. The user password is an encrypted shared secret. As a result, eavesdroppers can listen to these RADIUS requests and collect confidential information. Data protection is

necessary in roaming environments where the RADIUS packets travel across multiple administrative domains and untrusted networks. The RadSec module secures the communication between the switch and RADIUS server using a TLS connection. Using RADIUS over TLS provides users with the flexibility to host RADIUS servers across geographies and WAN networks.

HPE Aruba Networking recommends the usage of RadSec over RADIUS. Both IPv4 and IPv6 RadSec servers are supported.

To enable RADIUS security, use the **tls** parameter with the following command.



NOTE

Refer to the Security Guide for your switch for detailed steps to associate the TLS certificate for mutual authentication.

```
Switch(config)# radius-server host <FQDN/ipv4/ipv6> tls
```

To view the RadSec server configuration:

```
switch# show radius-server
Unreachable servers are preceded by *
***** Global RADIUS Configuration *****
Shared-Secret: None
Timeout: 10
Auth-Type: pap
Retries: 3
Initial TLS Connection Timeout: 30
TLS Timeout: 5
Tracking Time Interval (seconds): 300
Tracking Retries: 3
Tracking User-name: radius-tracking-user
Tracking Password: None
Status-Server Time Interval (seconds): 300
Number of Servers: 1
AAA Server Status Trap: Disabled

-----
-----
SERVER NAME                               | TLS | PORT | VRF
-----
-----
cppm.abcd.net                             | Yes | 1812 | mgmt
-----
-----
```

Hardening SSH

The following sections describe security and hardening workflows for SSH.

Public Key Authentication

Passwords are easy to use and remember, but they are vulnerable to attacks and human errors. Keys are more secure and efficient compared to passwords. SSH Public key authentication is enabled by default and takes precedence over password-based authentication. Validate users identified with SSH public keys stored in the local user database using the following commands.

```
Switch(config)# user admin authorized-key ecdsa-sha2-nistp256
E2VjZH...QUiCAk= root@switch
Switch# Show user <username> authorized-key
E2VjZH...QUiCAk= root@switch
```

Allow List

The SSH server access control can be implemented with an ACL applied to the control plane per VRF. A mistake in the configuration of the control-plane ACL applied to the **default** VRF might block other network protocols since the ACL involves rule ordering and can deny incoming packets. The SSH allow-list feature enhancement simplifies the configuration and protects against unauthorized SSH access. To use this feature, configure a list of addresses or prefixes that will be the only hosts allowed to connect to the SSH servers running on all VRFs of the switch. By default, the allow-list is disabled and any host is allowed to connect given the correct authentication criteria. When the allow-list is enabled, only the hosts that fall under one of the list entries may connect with the correct authentication criteria; all other hosts will be denied to attempt authentication.

```
switch(config)# ssh server allow-list
switch(config-ssh-al)# ip 10.10.0.0/16
switch(config-ssh-al)# ipv6 fd10::0/64
switch(config-ssh-al)# enable
Active SSH sessions will be terminated.
Do you want to continue (y/n)? y
switch(config-ssh-al)#exit
switch(config)# show ssh server allow-list
SSH server allow-list:
Status: Enabled
Allowed host IPs:
10.10.0.0/16
fd10::0/64
```



NOTE

If the ACL is applied to the control-plane and the SSH allow-list is also enabled, the control-plane ACL has pre-emption over the SSH allow-list.

Recommended Ciphers, MACs, and Algorithms

AOS-CX switches by default supports the following SSH Ciphers, MACs, and Algorithms:

```

switch # show ssh server
SSH server configuration on VRF default :
IP Version          : IPv4 and IPv6      SSH Version          : 2.0
TCP Port            : 22                  Grace Timeout (sec)  : 60
Max Auth Attempts   : 6                  Server Status        : running
Allow-list: disabled
Ciphers:
chacha20-poly1305@openssh.com, aes128-ctr, aes192-ctr, aes256-ctr,
aes128-gcm@openssh.com, aes256-gcm@openssh.co
Host Key Algorithms
ecdsa-sha2-nistp256, ecdsa-sha2-nistp384, ecdsa-sha2-nistp521,
ssh-ed25519, rsa-sha2-256, rsa-sha2-512, ssh-rsa
Key Exchange Algorithms:
curve25519-sha256, curve25519-sha256@libssh.org, ecdh-sha2-nistp256,
ecdh-sha2-nistp384, ecdh-sha2-nistp521
MACs:
hmac-sha2-256-etm@openssh.com, hmac-sha2-512-etm@openssh.com,
hmac-sha1-etm@openssh.com, hmac-sha2-256, hmac-sha2-512, hmac-sha1
Public Key Algorithms:
rsa-sha2-256, rsa-sha2-512, ssh-rsa, ecdsa-sha2-nistp256,
ecdsa-sha2-nistp384, ecdsa-sha2-nistp521, ssh-ed25519,
x509v3-rsa2048-sha256, x509v3-ssh-rsa, x509v3-sign-rsa,
x509v3-ecdsa-sha2-nistp256, x509v3-ecdsa-sha2-nistp384,
x509v3-ecdsa-sha2-nistp521

```

The previously mentioned default ciphers , message authentication codes (MACs), and algorithms are based on OpenSSH's default settings and are deemed secure by the community.

For highly secure deployments like Federal Accounts which mandates the compliance of NDcPP (Common Criteria Protection Profile), it is recommended to configure the following list of ciphers , MACs, and algorithms as per the NDcPP evaluation criteria.

```

switch(config)# ssh ciphers aes128-ctr, aes256-ctr, aes128-cbc, aes256-cbc
switch(config)# ssh macs hmac-sha2-256, hmac-sha2-512, hmac-sha1
switch(config)# ssh key-exchange-algorithms ecdh-sha2-nistp256, ecdh-sha2-
nistp384, diffie-hellman-group14-sha1
switch(config)# ssh host-key-algorithms ecdsa-sha2-nistp256, ecdsa-sha2-
nistp384,ecdsa-sha2-nistp521
switch(config)# ssh public-key-algorithms ecdsa-sha2-nistp256, ecdsa-sha2-
nistp384, ecdsa-sha2-nistp521

```

Individual algorithms are ordered and advertised to the peer SSH device as configured. Please order the algorithms appropriately to ensure that desired preference of algorithms

Server Port Customization

By default, SSH server listens on TCP port 22. This port will be used for all VRFs that have SSH server enabled. Optionally AOS-CX switches provides the ability to modify the default SSH server port to add extra

protection to the server. Supported Port number range from 1 to 65535. Although it is possible to use all ports, it might cause a network conflict. Thus, it is safer to choose a port number which is not reserved for any other service. Additionally ensure the firewall is not blocking the port you want to use for SSH.

Sample configuration to modify the SSH server port :

```
switch(config)# ssh server port 19222
```



NOTE

This port will be used for all VRFs that have an SSH server enabled. If the new port is currently opened by another service on a VRF, the SSH server will go into an error state for that VRF, and an event log message will be logged.

Two Factor Authentication and Authorization

Two factor Authentication is an extra layer of protection used to guarantee the secure access of switch management interfaces like SSH and HTTPS-Server. In two-factor authentication, X.509 certificate-based authentication is combined with RadSec authentication. Two-factor authentication can be performed locally or remote RadSec server. Refer security guide for detailed steps.

Following table summarizes the Two factor Authentication and Authorization support across different authentication methods – Local and Remote -

Task/Methods	Local Only	Local + Remote	Remote Only
Supported Management Interfaces	SSH	SSH	SSH and HTTPS - Server
X.509 Certificate Authentication	Validated using locally configured TA profile in switch	Validated using locally configured TA profile in switch	Validated using locally configured TA profile in switch
Validation of Username present in certificate's Common Name or Subject Alternative Name - User Principal Name	Local user Accounts	Local user Accounts	Remote RADIUS Authorize only request
Validation of Username and Password	Local user Accounts	Remote Server	No Validation.
Authorization	Local user Account	Remote Server	Remote Server

- Authorization requests are sent over TLS and therefore RADIUS authorize-only requires a RadSec RADIUS server. It should be supporting **Authorize** only request.
- For Remote only authentication , password is not required at the time of authentication.
- Your switch management computer has access to the REST API using an appropriate HTTPS client. This can be done with a web browser, using the WebUI, or other HTTPs request tools such as Postman. Usage of Firefox is not recommended, as it requires additional configuration to work with this feature.

Summary

The following table summarizes the management access methods available on an AOS-CX Switch, how they are secured by default, and the ways in which they can be secured.

Access Method	Secured by Default	Ways to Secure	Other Hardening Recommendations
Console	No	Enable AAA through External TACACS+/RADIUS/RadSec server or Local (Mandatory Fallback)	• Limiting Shell Access • Session Management
Telnet	No	Enable AAA through External TACACS+/RADIUS/RadSec server or Local	• Limiting Shell Access • Session Management • Control Plane ACLs
SSH	No	Enable AAA through External TACACS+/RADIUS/RadSec server or Local	• Limiting Shell Access • Session Management • Control Plane ACLs • hardening ssh
Web UI	No	Enable Authentication and Accounting through External TACACS+/RADIUS/RadSec server or Local. Authorization is supported via RBAC.	• Hardening PKI • TLS Enforcements • Control Plane ACLs
REST API	No	Enable Authentication and Accounting through External TACACS+/RADIUS/RadSec server or Local.	Control Plane ACLs

Access Method	Secured by Default	Ways to Secure	Other Hardening Recommendations
		Authorization is supported via RBAC	
SNMP	No	Refer to Securing SNMP Access	Control Plane ACLs

Session Management

Session management enhances security by enforcing specific CLI user session requirements for console, SSH and telnet connections. The following information is provided at the time of a successful login:

- When applicable, the number of failed login attempts since the most recent successful login.
- The date, time, and location (console or IP address or hostname) of the most recent previous successful login.
- The count of successful logins within the past (configurable) time period.

The following example configures CLI user session settings for a maximum of one concurrent session with a 15-minute timeout, and tracking for a maximum of 25 days

```
switch(config)# cli-session
switch(config-cli-session)# max-per-user 1
switch(config-cli-session)# timeout 15
switch(config-cli-session)# tracking-range 25
switch# exit
```

It is recommended to configure at least five to ten minutes of timeout for sensitive networks. For non-sensitive networks, a 15 minute timeout is recommended.

When the same user name is used for both local and remote authentication, both users, regardless of privilege level, are considered to be the same user for the purpose of counting concurrent CLI sessions. For example, with **max-per-user** value set to **1** and user **admin1** configured for local and remote authentication, only the local user **admin1** or the remote user **admin1** can be logged in at any given moment. Both admin1 users cannot be logged in simultaneously unless the **max-per-user** value is increased to at least **2**.

Limiting Shell Access

The AOS-CX operating system provides access to the underlying Linux system, allowing administrators to launch a bash shell session from the switch command-line interface. Misuse of shell access could expose sensitive network traffic to an unauthorized third party via packet mirroring to a remote device or could

cause a denial of service by modifying or removing system files. This file modification could render the device unbootable, and require software restoration through the ServiceOS console..

The following are best practices for limiting shell access:

- Disable access to the Bash shell by changing the switch security mode to **enhanced** from ServiceOS.
- Limit shell access by using RBAC or an external TACACS+ authorization server to deny access to the start-shell command to all users except those who specifically require it.

Securing SNMP Access

SNMP is used to manage and monitor networked devices from a centralized platform. There are three versions of the SNMP protocol: v1, v2c, and v3. SNMPv1 and v2c use community names for read and write access. Much like passwords are used for authentication, these community names are sent across the wire as clear text. If a malicious user were to capture these community names, they could potentially issue SNMP **set** commands to make unauthorized and potentially harmful configuration changes to a network device. SNMPv3, by comparison, utilizes a user-based security model with both authentication and privacy protocols to prevent unauthorized access or eavesdropping of management traffic.

SNMP is disabled by default on all AOS-CX devices. When enabled, SNMP provides limited write support in addition to read-only access and trap support for SNMP v1, v2c, and v3.

The default SNMP community string is public, a common setting for SNMP-capable devices. Replace the public community string with another value that is hard to guess , but note that this doesn't fully prevent against attacks as this string is in clear text format in packet captures:

```
Switch(config)# snmp-server community zerotrust
```

The default access level for SNMP communities is read-only; if read-write support is required, set the access level for the community to **rw** from the community context. IPv4 and/or IPv6 ACLs may be used to limit access to allowed management stations or subnets; only one ACL (IPv4 or IPv6) may be applied to a community at a time. Apply an IPv4 or IPv6 ACL from the SNMP **config-community** context.

```
switch(config)# snmp-server community zerotrust
switch(config-community)# access-level rw
switch(config-community)# access-list snmp_acl
switch # show snmp community
```

```
-----
-----
Community                Access-level ACL Name                ACL Type
View
-----
-----
zerotrust                 rw                snmp_acl                ipv4
none
```

Best practices is to use SNMPv3 instead of older versions of SNMP. Older versions of SNMP are unauthenticated and unencrypted, with the community string acting as a password, transmitted in plaintext. SNMPv3, offers support for different users, authentication, and strong encryption. AOS-CX supports stronger authentication protocols (SHA224, SHA256, SHA384, and SHA 512) and privacy protocols (AES192 and AES256).

To create an SNMPv3 user using SHA for authentication and DES for privacy:

```
switch(config)# snmpv3 user myUser auth sha auth-pass plaintext myAuthPswrd
priv des priv-pass plaintext myPrivPswrd
```

The following example creates an SNMPv3 context with the community name created above and assigned to the mgmt VRF:

```
switch(config)# snmpv3 context snmpv3mgmt vrf mgmt community zerotrust
```

Disable support for SNMPv1 and SNMPv2c and only accept SNMPv3 messages using the following command:

```
switch(config)# snmp-server snmpv3-only
```

To enable SNMP on the **mgmt** VRF:

```
switch(config)# snmp-server vrf mgmt
switch# show snmpv3 context
-----
-----
Name                vrf                Community
Type[Instance_id]
-----
-----
snmpv3mgmt          mgmt                zerotrust          vrf
switch# show snmpv3 users
-----
-----
User                AuthMode PrivMode Status   Context        Access-level
View
-----
-----
myUser              sha       des      Enabled  none
ro                  none
```

Control Plane ACLs

Once an IP address is bound to an interface associated with a VRF, the switch may become exposed to management access from untrusted users or devices. This potential point of vulnerability can be mitigated

by binding an Access Control List (ACL) to the control plane for that VRF. The control plane handles the device's management and routing functionality.

Once a control plane ACL is applied to a VRF, it filters packets to all IPv4/IPv6 addresses bound to the device on that VRF. It is possible to create a control plane ACL for each existing VRF, including the **mgmt** VRF.

The following commands are an example of an ACL an administrator can apply that limits SSH and SNMP control plane access to source devices with IP addresses in the 10.10.0.0/24 subnet, with counters for denied SSH and SNMP packets.

```
switch(config)# access-list ip CONTROLPLANE
switch(config-acl-ip)# 05 comment ALLOW SSH AND SNMP ON ADMIN SUBNET, BLOCK
ALL OTHERS
switch(config-acl-ip)# 10 permit tcp 10.10.0.0/24 any eq 22
switch(config-acl-ip)# 20 permit udp 10.10.0.0/24 any eq 161
switch(config-acl-ip)# 30 permit udp 10.10.0.0/24 any eq 162
switch(config-acl-ip)# 40 deny tcp any any eq 22 log count
switch(config-acl-ip)# 50 deny udp any any eq 161 log count
switch(config-acl-ip)# 60 deny udp any any eq 162 log count
switch(config-acl-ip)# 990 comment ALLOW ANYTHING ELSE
switch(config-acl-ip)# 1000 permit any any any
```



NOTE

Event logs for Control Plane ACE is supported using the **log** keyword. This option offers better troubleshooting and visibility of an ACL applied to the control plane.

To apply this ACL to the default VRF:

```
switch(config)# apply access-list ip CONTROLPLANE control-plane vrf default
```

All ACLs in AOS-CX have an implicit **deny any** rule at the end of the rules list. This requires that allowed traffic be explicitly permitted to pass through an applied ACL. In the above example, SSH and SNMP traffic on ports 22 is allowed from 10.10.0.0/24. The SSH and SNMP traffic is then blocked from any other subnets. The final ACL entry (**permit any any any**) permits all other traffic.

Time Synchronization

Many secure protocols and auditing functions rely on system times being synchronized with a reliable time source, either within or (where security considerations permit) external to the managed network. One of the most commonly-used protocols to accomplish this is the Network Time Protocol (NTP), which can use both local and Internet-hosted servers to synchronize system time across a network. Recommendation - NTP should be configured and enabled on the device prior to enabling secure management protocols.

A common practice among organizations that span multiple time zones is to use NTP to synchronize time clocks and set the local time zone on all equipment to UTC. This practice aids in troubleshooting and security audits for devices that might be continents apart. Both IPv4 and IPv6 Servers are supported.

To configure a switch to use NTP authentication and connect to a local NTP server at 10.100.1.254 using the switch management port:

```
switch(config)# ntp authentication
switch(config)# ntp authentication-key 1 md5 ntpauthkey
switch(config)# ntp server 10.100.1.254 prefer
switch(config)# ntp vrf mgmt
switch# show ntp servers
-----
NTP SERVER      KEYID    MINPOLL    MAXPOLL  OPTION  VER
-----
10.100.1.254    --       6          10       none    4 prefer
10.80.2.219     --       6          10       iburst  4 prefer(auto)
pool.ntp.org     --       4          4        iburst  4
-----

switch# show ntp authentication-keys
-----
-----
Key ID    Trusted  Type      Encrypted Key
-----
-----
1         No       MD5
AQBapUtt1YTjZS2PH4+J7G5OKJG0GuZ2WxmD0339TNg6nfGXY=
-----
-----

switch# show ntp status
NTP Status Information
NTP                      : Enabled
NTP DHCP                 : Enabled
NTP Authentication       : Enabled
NTP Server Connections   : Using the mgmt VRF
System time              : Fri Mar  8 03:51:46 PST 2024
NTP uptime               : 8 days, 15 hours, 24 minutes, 37 seconds
Not synchronized with an NTP server.
```

Secure Copy

The **copy** command is widely used in AOS-CX switches to transfer files, configurations and log messages. The commonly used file transfer protocol TFTP transfers files in plaintext, so attackers can easily capture transferred packets. To protect the device against security threats, it is recommended to use **SFTP** and **SCP** to perform the copy operations.

Hardening PKI

The Public Key Infrastructure (PKI) feature enables administrators to manage digital certificates on the switch. The switch uses certificates to validate clients when acting as a server, and when communicating with servers when TLS encryption is used.

The AOS-CX Switch Series supports the installation of certificate authority (CA) certificates and the generation and installation of leaf certificates. The switch supports 64 trust anchor (TA) profiles. Each TA profile stores a trusted CA certificate. The certificate can be either a root CA certificate, which must be self-signed, or an intermediate CA certificate that is issued by another CA. The TA profile also enables configuration of real-time checking of certificate revocation (through OCSP).

Leaf certificates can be installed on the switch for use by applications such as:

- RadSec Client
- dot1x-supPLICant
- EST Client
- captive-portal
- syslog client
- https-server - Web UI or REST API

AOS-CX switches by default supports the following preinstalled leaf certificates:

- **local-cert:** A self-signed certificate that switch automatically generated at first boot, as the default certificate for any application when the application's associated certificate is not configured
- **device-identity:** A device-identity certificate built into a switch at manufacturing and resident for the life of the product. The identity is a combination of an RSA key pair with physical information such as the unit's model, chassis/PCA serial number, and base MAC ID. Device Identity will be used for following purposes:
 - —Allow 801.2X-2010 to perform peer authentication without the need for certificate or pre-shared key installation to automate the formation of MACsec secure channels between neighbor devices.
 - Authentication with HPE Aruba Networking cloud services.

```
switch # show crypto pki certificate
Certificate Name      Cert Status      EST Status      Associated
Applications
-----
local-cert           installed        n/a             captive-portal, dot1x
```

supplicant, est-client, https-server, radsec-client, syslog-client			
device-identity	installed	n/a	none



NOTE

AOS-CX recommends the usage of trusted CA signed certificate over the self-signed certificate for all the applications to avoid potential security risks.

If you are purchasing a certificate from a trusted CA, the switch can generate the certificate signing request (CSR) that is used to request the certificate. The switch can also directly generate self-signed certificates. Alternatively, the certificate and private key can be generated outside the switch and then imported. X509 certificate management software such as OpenSSL can be used to generate the private key and CSR and then combine the certificate and private key into one PEM or PKCS#12 file suitable for import into the switch.

The following procedure describes how to create and install an X.509 leaf certificate that is initiated inside the switch but signed outside the switch by a Certificate Authority.

```
switch(config)# crypto pki ta-profile root-cert
switch(config-ta-root-cert)# revocation-check ocsp
switch(config-ta-root-cert)# ocsp url primary http://ocsp-server.site.com
switch(config-ta-root-cert)# ocsp url secondary http://ocsp-server2.site.com
switch(config-ta-root-cert)# ta-certificate import terminal
Paste the certificate in PEM format below, then hit enter and ctrl-D:
switch(config-ta-cert)# -----BEGIN CERTIFICATE-----
switch(config-ta-cert)#
MIIDuTCCAqECCQCuoxeJ2ZNYcjANBgkqhkiG9w0BAQsFADCBqzELMAEBh
switch(config-ta-cert)#
VVMxEzARBgNVBAgMCkNhbgG1mb3JuaWExEDAOBgNVBACMB1JvY2tsDAKBg
switch(config-ta-cert)#
BAoMA0hQTjEVMBMGA1UECwwMSFB0Um9zZXZpbGx1MSowKAYDVQocG5zdz
switch(config-ta-cert)# x3WFf3dFZ8o9sd5LVAHneH/
ztb9MP34z+le1V346r12L2kpxmTOVJVyTO
switch(config-ta-cert)# BizD/ST/HaWI+0S+S80rm93PSscEbb9GWk7vshh5EnW/
moehBKcE40lzy
switch(config-ta-cert)#
3LvMLZcssSe5J2Ca2XIhfDme8UaNZ7syGYMsAW0nG7yYHWkEOQu9s
switch(config-ta-cert)# -----END CERTIFICATE-----
switch(config-ta-cert)#
The certificate you are importing has the following attributes:
Issuer: C=US, ST=CA, L=Rocklin, O=Company, OU=Site,
CN=site.com/emailAddress=test.ca@site.com
Subject: C=US, ST=CA, L=Rocklin, O=Company, OU=Site,
CN=8400/emailAddress=test.ca@site.com
Serial Number: 12121221634631568498 (0xaea51217d5945772)
TA certificate import is allowed only once for a TA profile
Do you want to accept this certificate (y/n)? y
```

```

TA certificate accepted.
switch(config-ta-root-cert)# exit
switch(config)# crypto pki certificate lcert
switch(config-cert-lcert)# subject common-name Leaf country US state CA
locality Rocklin org Company org-unit Site
switch(config-cert-lcert)# key-type rsa key-size 3072
switch(config-cert-lcert)# enroll terminal
You are enrolling a certificate with the following attributes:
Subject: C=US, ST=CA, L=Rocklin, O=Company, OU=Site
CN=Leaf
Key Type: RSA (2048)
Continue (y/n)? y
-----BEGIN CERTIFICATE REQUEST-----
MIIBozCCAQwCAQAwYzEVMBMGAlUEAxMMcG9kMDEtODQwMC0xMQ4wDAYDV
nViYTEMMAoGA1UEChMDSFBFMRIwEAYDVQQHEw1Sb3Nldm1sbGUxCzAJBg
NBMQswCQYDVQQGEwJVUzCBnzANBgkqhkiG9w0BAQEFAAOBjQAwgYkCgYE
...
GBAJ4L3lFFfWBEL+KAKpOGjZcVmwlBMqSKFtOFNF9nzmUmONmU3SKy6dz
7Au22mf3lWDxzrtCC/dj5RtWJeJekxp2LCIK/3eRXUwbYveQDKcxH7j9Z
ace+2tA68F2vlgRCQ/hcQH0YmNuaq4Ne3w0dhm7HlUrx
-----END CERTIFICATE REQUEST-----
switch(config-cert-lcert)# import terminal ta-profile root-cert
Paste the certificate in PEM format below, then hit enter and ctrl-D:
switch(config-cert-import)# -----BEGIN CERTIFICATE-----
switch(config-cert-import)#
MIIFRDCCAYygwIBAgIQPnnS2Vp5u07XMdktDJzANBgkqhkiG9w0Bv
switch(config-cert-import)#
MQswCQYDVQQGEwJVEOMAwG1UECgwFJlYmxDAOgNBMMB1Jvb3QgQ0Ew
switch(config-cert-import)#
HhcNMTkNDEwMjIwNTWcjIwMTA0MjwNE1WBzQswQYDVQQGEwJVUzEL
...
switch(config-cert-import)#
1fIYZYGQyla0AwFuTTxBXYwRxPbUYU5tumrfwRPmE4OVY8S9DQgcr
switch(config-cert-import)# 1NGNm3NG03GqPcs/T9bVyF5BOrS5lmm7kNfRYl8D/
kMTfRreSdxis
switch(config-cert-import)# YQ1ulNqShps=
switch(config-cert-import)# -----END CERTIFICATE-----
switch(config-cert-import)#
Leaf certificate is validated with root-cert and imported successfully.
switch(config-cert-lcert)# exit
switch(config)# crypto pki application syslog-client certificate lcert

```

Mandatory matching of peer device hostname

To enhance the server-side certificate verification, the AOS-CX switch checks that the peer device configured hostname matches either the Subject Alternative Name (SAN) field or the Common Name (CN) within the certificate Subject field. If the SAN field is present and matches the hostname, validation succeeds, otherwise it fails. If the SAN field is not present, and the CN matches the hostname, validation succeeds, otherwise it fails.

EST

EST stands for Enrolment over Secure Transport; An EST client is implemented as a part of the PKI infrastructure in the AOS-CX switches. Switches can be configured to request the trusted CA certificates and to request enrolment/reenrolment of leaf certificates automatically, without the need for administrator intervention, while maintaining the security and integrity of the whole enrolment process.

Refer the **PKI EST** section in Security Guide for more information.

TLS Enforcements

Minimum TLS version supported in AOS-CX switches is TLS1.2. The following are recommended cipher suites for TLS Applications/Protocols

- TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256
- TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
- TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256
- TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384

The Extended Key Usage X.509 v3 extension defines one or more purposes for which the public key can be used. This is in addition to or in place of the basic purposes specified by the Key Usage extension. As per NDcPP recommendation, that a peer certificate being used to establish TLS connection must have its extended key usage field set as client-auth or server-auth, depending on its role of the peer device. This configuration enables the checking of key usage during TLS handshake. It is disabled by default

```
switch(config)# tls check-key-usage
switch# show tls
TLS crypto algorithms state: default
TLS key usage checking      : on
```

Secure Logging

AOS-CX Switch provides both locally stored event and security logs, as well as using the syslog protocol to forward events to a remote IPv4/IPv6 syslog server for auditing purposes. Logged events can be filtered by severity level, originating system modules, or using regular expressions to match against message text.

When configuring AOS-CX to send logs to a remote server, it is common practice to set a facility value. This value acts as a label that the remote server can use to determine which file the syslog message should get appended.

Below is an example of how to configure AOS-CX to send event log messages via syslog to a remote server. This example uses the default facility of local7 and sends event messages marked informational and higher:

```
switch(config)# logging 10.100.1.250 vrf mgmt
```

To include security-related accounting logs in addition to the event logs, then add the include-auditable-events option to the configuration:

```
switch(config)# logging 10.100.1.250 include-auditable-events vrf mgmt
```

The syslog client can connect to a server using UDP (default), TCP, or TLS protocols. TLS is the recommended protocol, as it provides an encrypted connection to the syslog receiver. This requires the switch to possess a signed TLS client certificate, and the receiver to possess a signed TLS server certificate. The process of requesting and installing a signed TLS client certificate for syslog is similar to that for requesting and installing an SSL/TLS certificate for web-management.

Hardening the Control Plane

The following sections describe strategies for securing and hardening the switch control plane

Control Plane Policing

Control Plane Policing prevents flooding of certain types of packets from overloading the switch or module CPU by either rate-limiting or dropping packets.

The switch software provides several configurable classes of packets that can be rate-limited, including (but not limited to) ARP broadcasts, multicast, routing protocols (BGP, OSPF), and spanning tree. CoPP is always active and cannot be disabled.

The following default CoPP policy applies the following traffic class definitions and rate limits (in packets per second) on 6300 series switch series:

```
switch# show copp-policy default
```

class	drop	priority	rate pps	burst pkts	hardware rate pps
acl-logging	0	25	25	25	
arp-broadcast	2	1250	1250	1250	
arp-protect	2	2075	2075	2075	
arp-unicast	3	825	825	825	
bfd-control	5	850	850	850	
bgp	5	750	750	750	
captive-portal	2	2075	259	2075	
client-onboard	5	1024	1024	1000	
dfp-collector	0	512	512	500	
dhcp	2	750	750	750	
erps	6	225	225	225	
fib-optimization	0	100	200	100	
icmp-broadcast-ipv4	2	325	325	325	
icmp-multicast-ipv6	2	475	475	475	
icmp-security-ipv6	2	325	325	325	

icmp-unicast-ipv4	3	225	225	225
icmp-unicast-ipv6	3	400	400	400
ieee-8021x	2	2075	259	2075
igmp	4	1600	450	1600
ip-exceptions	0	100	100	100
ip-lockdown	0	100	100	100
ip-tracker	0	256	256	250
ipfix	0	2500	2500	2500
ipsec	5	1025	128	1025
ipv4-options	1	100	100	100
lACP	5	2050	2050	2050
lldp	5	100	100	100
loop-protect	6	225	225	225
mac-lockout	0	100	100	100
manageability	4	4218	4218	4200
mdns	2	150	150	150
mirror-to-cpu	0	100	100	100
mld	4	1600	450	1600
mvrp	5	225	225	225
nae-packet-monitor	0	100	200	0
ntp	4	100	100	100
ospf-multicast	5	1025	1025	1025
ospf-unicast	5	1025	1025	1025
pim	5	1700	1700	1700
ptp	5	1000	250	1000
secure-learn	2	2075	259	2075
sflow	1	1000	125	1000
stp	6	2000	2000	2000
udld	6	450	450	450
unknown-multicast	1	1025	128	1025
unresolved-ip-unicast	1	325	325	325
vrrp	4	400	400	400
default	2	4225	528	4225

The default CoPP policy can be modified but cannot be deleted.

To revert a modified default CoPP policy to factory default settings:

```
switch(config) # copp-policy default revert
```

Administrators may create up to 32 custom CoPP policies, though only one can be active at any given time.

To create and apply a simple custom CoPP policy:

```
switch(config) # copp-policy copp_policy_01
switch(config-copp) # class arp-broadcast priority 2 rate 1000 burst 1000
switch(config-copp) # class unknown-multicast priority 2 rate 1000 burst 1000
```

```
switch(config-copp) # class unresolved-ip-unicast priority 2 rate 1000 burst 1000
switch(config-copp) # default-class priority 1 rate 3000 burst 3000
switch(config-copp) # exit
switch(config) # apply copp-policy copp_policy_01
```

To remove a custom CoPP policy from service and automatically apply the default policy

```
switch(config) # no apply copp-policy copp_policy_01
```

To delete a custom CoPP policy:

```
switch(config) # no copp-policy copp_policy_01
```

An active custom CoPP policy cannot be deleted; it must first be removed from service using the above command.

NAE Scripts

The Network Analytics Engine is a first-of-its-kind built-in framework for network assurance and remediation. Combining the full automation and deep visibility capabilities of the AOS-CX operating system, this unique framework enables monitoring, collecting network data, evaluating conditions, and taking corrective actions through simple scripting agents. This engine is integrated with the AOS-CX system configuration and time series databases, enabling to examine historical trends and predict future problems due to scale, security, and performance bottlenecks. With that information, administrators can create software modules that automatically detect such issues and take appropriate action.

The following list describes the [HPE Aruba Networking Github](#) scripts hosted on the HPE Aruba Networking Solution Exchange. These scripts can help in hardening the switch control plane. These scripts can help in hardening the switch control plane.

Table 1. HPE Aruba Networking certified NAE scripts

Module	Objective	Script
Control Plane Policing	The purpose of this script is to detect anomalous traffic that is getting dropped by Control Plane Policing.	<u>copp.5.1</u>
Spanning Tree	This script monitors the STP BDU counters, Topology Change Notifications (TCN) and raise an alert if the rate of TCN exceeds a certain threshold value for a specified time	<u>tp_bpdu_tcn_rate_monitor.2.0</u>

Module	Objective	Script
	. It also monitors the number of ST P packets dropped at CoPP.	
ARP	The purpose of this script is to help in monitoring the number of ARP requests coming to the switch CPU.	<u>arp_request_monitor.2.0</u>

Trusted Supply Chain

HPE is a leader in the ICT (Information and Communication Technology) industry for supply chain cybersecurity. HPE recognizes the importance of secure software and hardware development, enabling the availability of parts from trusted sources, building products with advanced security features, and accessing data that is protected within secure environments.

As cybersecurity threats evolve, HPE continues to identify and mitigate cybersecurity risks within the supply chain and provide secure products so you can concentrate on your business goals.

Supply chain attacks caused by malicious actors infiltrating systems through partners or technology vendors with access to data and resources are on the rise. Mitigating cybersecurity risks and preventing attacks in the supply chain is essential to provide secure products and services. Following are the list of security best practices that can be followed from AOS-CX switching perspective.

- Boot the switch in [Enhanced Secure Mode](#).
- Disable the [USB Auxiliary port](#) when not in use.
- Disable all physical interfaces and the OOBM port using the following commands:

```
switch(config)# interface <physical interface range>
switch(config)# disable
switch(config)# exit
switch(config)# interface mgmt
switch(config)# shutdown
switch(config)# exit
```

- Disable all management protocols (https-server, SSH, SNMP) and force the console into the device configuration to disable the management protocols on all the enabled VRFs using the following commands:

```
switch(config)# no ssh server vrf <vrf-name>
switch(config)# no https-server vrf <vrf-name>
switch(config)# no snmp-server vrf <vrf-name>
```

- Enable [password complexity](#) with a strict set of requirements.

- Enable the ServiceOS password prompt.
- Disable the HPE Aruba Networking Central client using the following commands:

```
switch(config) # hpe-anw-central
switch(config-hpe-anw-central) # disable
switch(config-hpe-anw-central) # exit
```

- Enable only NDcPP approved SSH algorithm

Support and Other Resources

Access HPE Aruba Networking support and updates, and view warranty and regulatory information

Subtopics

Accessing HPE Aruba Networking Support

Accessing Updates

Warranty Information

Regulatory Information

Documentation Feedback

Accessing HPE Aruba Networking Support

Table 1. Contact Information

Main Site	<u>arubanetworks.com</u>
Support Site	<u>https://networkingsupport.hpe.com/</u>
AOS - CX Switch Software Documentation Portal	<u>https://www.arubanetworks.com/techdocs/AOS - CX/help_portal/Content/home.htm</u>
Airheads Social Forums and Knowledge Base	<u>community.arubanetworks.com</u>
North American Telephone	1 - 800 - 943 - 4526 (US and Canada Toll - Free Number)
International Telephone	<u>arubanetworks.com/support - services/contact - support/</u>

Software Licensing Site	https://licensemanagement.hpe.com
End - of - life Information	https://networkingsupport.hpe.com/notifications
Security Incident Response Team	Site: https://support.hpe.com/connect/s/securitybulletinlibrary Email: aruba - sirt@hpe.com

Be sure to collect the following information before contacting Support:

- Technical support registration number (if applicable)
- Product name, model or version, and serial number
- Operating system name and version
- Firmware version
- Error messages
- Product-specific reports and logs
- Add-on products or components
- Third-party products or components

Other useful sites

Other websites that can be used to find information:

AOS - CX Software Technical Update channel on YouTube.	Videos on new features introduced in this release : https://www.youtube.com/playlist?list=PLsYGHuNuBZcbWPEjjHuVMqP - Q_UL3CskS
HPE Aruba Networking Hardware Documentation and Translations Portal	https://www.arubanetworks.com/techdocs/hardware/DocumentationPortal/Content/home.htm
HPE Aruba Networking software	https://networkingsupport.hpe.com/downloads https://networkingsupport.hpe.com/downloads
Software licensing and Feature Packs	https://licensemanagement.hpe.com/
End - of - Life information	https://networkingsupport.hpe.com/end - of - life

Accessing Updates

You can access updates from the HPE Aruba Networking Support Portal at <https://networkingsupport.hpe.com>.

Some software products provide a mechanism for accessing software updates through the product interface. Review your product documentation to identify the recommended software update method.

To subscribe to eNewsletters and alerts:

<https://networkingsupport.hpe.com/notifications/subscriptions> (requires an active HPE Aruba Networking Support Portal account to manage subscriptions). Security notices are viewable without an HPE Aruba Networking Support Portal account.

Warranty Information

To view warranty information for your product, go to <https://www.arubanetworks.com/support-services/product-warranties/>.

Regulatory Information

To view the regulatory information for your product, view the Safety and Compliance Information for Server, Storage, Power, Networking, and Rack Products, available at <https://www.hpe.com/support/Safety-Compliance-EnterpriseProducts>

Additional regulatory information

HPE Aruba Networking is committed to providing our customers with information about the chemical substances in our products as needed to comply with legal requirements, environmental data (company programs, product recycling, energy efficiency), and safety information and compliance data, (RoHS and WEEE). For more information, see <https://www.arubanetworks.com/company/about-us/environmental-citizenship/>.

Documentation Feedback

HPE Aruba Networking is committed to providing documentation that meets your needs. To help us improve the documentation, send any errors, suggestions, or comments to Documentation Feedback ([**docsfeedback-switching@hpe.com**](mailto:docsfeedback-switching@hpe.com)). When submitting your feedback, include the document title, part number, edition, and publication date located on the front cover of the document. For online help content, include the product name, product version, help edition, and publication date located on the legal notices page.